الدبلوم العالي في حوكمة الأمن السيبراني

# حوكمة الأمن السيبراني

محاضرات المادة مجمّعة في ملف واحد – إعداد وتقديم: أ.د. ضياء جاسم كاظم

1. الأسبوع الأول: مقدمة في الأمن السيبراني وحوكمة أمن المعلومات
2. الأسبوع الثالث: إطار NIST CSF 2.0 ووظيفة الحوكمة (Govern)
3. المحاضرة الرابعة: معيار ISO 27014 و ISO 27001
4. إطار COBIT 2019 وحوكمة تكنولوجيا المعلومات
5. الأسبوع السادس: إدارة المخاطر السيبرانية

**مبارك النعيمي**

# مقدمة في الأمن السيبراني وحوكمة أمن المعلومات

محاضرة الأسبوع الأول ـــــمدة المحاضرة :ساعة ونصف

إعداد وتقديم :أ.د. ضياء جاسم كاظم

عن هذه المحاضرة

# لمحة عامة عن محاضرة اليوم

1 **المدة الزمنية**

ساعة ونصف موزعة على محورين رئيسيين مع فاصل نقاش

2 **المحور الأول**

مدخل شامل إلى مفاهيم الأمن السيبراني الأساسية

3 **المحور الثاني**

مدخل إلى حوكمة أمن المعلومات ودورها في حماية المؤسسات

4 **الأسلوب**

عرض نظري مدعوم بأمثلة واقعية ونقاش تفاعلي

# بنهاية هذه المحاضرة سيكون الطالب قادراً على

1. تعريف الأمن السيبراني وتوضيح أهميته للمؤسسات والأفراد
2. شرح مثلث CIAوالمبادئ الأساسية لأمن المعلومات
3. تصنيف أبرز التهديدات السيبرانية والفاعلين وراءها
4. تعريف حوكمة أمن المعلومات والتمييز بينها وبين الإدارة التنفيذية
5. التعرف على أركان الحوكمة وأصحاب المصلحة الرئيسيين

خطة المحاضرة

# جدول أعمال الساعة والنصف

1

## مدخل إلى الأمن السيبراني

التعريفات، الأهمية، التطور التاريخي، مثلث CIA — 25 دقيقة

2

## التهديدات والفاعلون

أنواع الهجمات، الجهات المهاجمة، أمثلة واقعية — 20 دقيقة

3

## استراحة ونقاش قصير

أسئلة وتفاعل مع الطلاب — 5 دقائق

4

## مدخل إلى الحوكمة

تعريف الحوكمة، أركانها، أصحاب المصلحة — 25 دقيقة

5

## الأطر والتشريعات

لمحة تمهيدية عن الأطر القادمة والبيئة التنظيمية — 10 دقائق

6

## الملخص والمصطلحات

مراجعة عامة، أسئلة نقاش، تحضير للأسبوع القادم — 5 دقائق

١

# مدخل إلى الأمن السيبراني

المفاهيم الأساسية والأهمية والتطور التاريخي

# ما هو الأمن السيبراني؟

1 **التعريف العام**

مجموعة الممارسات والتقنيات والسياسات التي تهدف إلى حماية الأنظمة والشبكات والبيانات من الوصول غير المصرح به أو الهجمات أو الأضرار

2 **النطاق**

يشمل حماية الأجهزة، البرمجيات، الشبكات، البيانات، وحتى سلوك المستخدمين أنفسهم

3 **الهدف النهائي**

ضمان استمرارية الأعمال، حماية الخصوصية، والحفاظ على ثقة أصحاب المصلحة

لماذا يهم الأمن السيبراني؟

# الأمن السيبراني في صميم استمرارية الأعمال

**24/7**

المؤسسات تتعرض لمحاولات اختراق واستطلاع مستمرة على مدار الساعة

**↑٪**

ارتفاع مستمر في تكلفة الحوادث السيبرانية وتأثيرها على السمعة

**بيانات**

تحوّل البيانات إلى أصل استراتيجي يستوجب حماية مماثلة للأصول المالية

*الأرقام الدقيقة تختلف حسب القطاع والتقارير السنوية الصادرة عن جهات عالمية متخصصة.*

لمحة تاريخية

# تطور الأمن السيبراني عبر الزمن



# مثلث CIA لأمن المعلومات

س

### السرية Confidentiality

ضمان عدم اطلاع غير المصرح لهم على المعلومات الحساسة

ص

### السلامة Integrity

ضمان دقة البيانات واكتمالها وعدم التلاعب بها دون تصريح

ت

### التوافر Availability

ضمان وصول المستخدمين المخولين للمعلومات والأنظمة عند الحاجة

# مبادئ إضافية لأمن المعلومات

1. **Authentication المصادقة**
   التحقق من هوية المستخدم أو الجهة قبل منح الوصول

2. **Authorization التفويض**
   تحديد الصلاحيات المسموح بها لكل مستخدم بعد التحقق من هويته

3. **Non-repudiation عدم الإنكار**
   ضمان عدم قدرة أي طرف على إنكار قيامه بعملية معينة

4. **Accountability المساءلة**
   ربط كل نشاط بجهة أو شخص مسؤول عنه، ومهمة أساسية تربط الأمن بالحوكمة

# أبرز أنواع التهديدات الشائعة

1

## البرمجيات الخبيثة

فيروسات وديدان وأحصنة طروادة تُصيب الأنظمة وتُلحق الضرر بها

2

## برمجيات الفدية

تشفير بيانات الضحية والمطالبة بفدية مالية لاستعادتها

3

## التصيد الاحتيالي

رسائل مزيفة تخدع المستخدم للكشف عن بيانات حساسة

4

## هجمات حجب الخدمة

إغراق الأنظمة بالطلبات لتعطيلها عن العمل الطبيعي

5

## الهندسة الاجتماعية

استغلال الثقة والسلوك البشري بدلاً من الثغرات التقنية

6

## التهديدات الداخلية

موظفون أو أطراف موثوقة يسيئون استخدام صلاحياتهم

الفاعلون في التهديدات

# من يقف خلف الهجمات السيبرانية؟

1

## قراصنة أفراد

أفراد يسعون لتحقيق مكاسب مادية أو إثبات القدرة التقنية

2

## جماعات إجرامية منظمة

شبكات منظمة تستهدف المؤسسات بدافع الربح المالي

3

## جهات مدعومة من دول

هجمات موجهة لأغراض استخباراتية أو سياسية أو عسكرية

4

## الناشطون السيبرانيون

هجمات بدوافع أيديولوجية أو سياسية أو اجتماعية

# أبرز المنافذ التي يستغلها المهاجمون

1. البريد الإلكتروني والمرفقات أو الروابط الخبيثة
2. الثغرات غير المحدّثة في الأنظمة والتطبيقات
3. كلمات المرور الضعيفة أو المسرّبة
4. الأجهزة المحمولة وشبكات الواي فاي غير الآمنة
5. الأطراف الثالثة والموردون المرتبطون بالمؤسسة

دروس من الواقع

# لماذا تحدث هذه الاختراقات غالباً؟

1

### ضعف الوعي البشري

غالبية الحوادث تبدأ بخطأ بشري أو نقص في التدريب والتوعية

2

### غياب التحديثات

تأخر تطبيق التحديثات الأمنية يترك ثغرات معروفة مفتوحة

3

### ضعف الحوكمة

غياب سياسات واضحة وأدوار محددة يُضعف الاستجابة للحوادث

# المجالات الرئيسية للأمن السيبراني

1

## أمن الشبكات

حماية البنية التحتية للشبكات من الاختراق والتنصت

2

## أمن التطبيقات

تأمين البرمجيات من مرحلة التصميم حتى التشغيل

3

## أمن السحابة

حماية البيانات والخدمات المستضافة على بيئات سحابية

4

## أمن البيانات

حماية سرية وسلامة البيانات أثناء التخزين والنقل

5

## أمن نقاط النهاية

تأمين الأجهزة الطرفية كالحواسيب والهواتف

6

## الاستجابة للحوادث

الكشف عن الحوادث الأمنية والتعامل معها بسرعة وفعالية

٢

# حوكمة أمن المعلومات

من الحماية التقنية إلى القيادة والمساءلة المؤسسية

# ما هي الحوكمة؟

1

## تعريف عام

مجموعة الأنظمة والعمليات التي توجّه وتراقب أداء المؤسسة لتحقيق أهدافها

2

## الفكرة الجوهرية

الحوكمة تجيب عن سؤال :من يقرر؟ وكيف تتم المساءلة؟

3

## التطبيق في الأمن السيبراني

امتداد لمفهوم الحوكمة المؤسسية العامة ليشمل حماية المعلومات والأنظمة

التعريف المتخصص

# ما المقصود بحوكمة أمن المعلومات؟

1 **التعريف**

الإطار الذي يحدد من خلاله مجلس الإدارة والإدارة التنفيذية التوجهات والأهداف والمسؤوليات المتعلقة بأمن المعلومات

2 **الربط الاستراتيجي**

مواءمة استراتيجية الأمن السيبراني مع أهداف العمل العامة للمؤسسة

3 **بُعد المساءلة**

تحديد من يملك القرار، ومن يُساءل عند وقوع حادث أمني

# لماذا تحتاج المؤسسات إلى حوكمة أمنية؟

1

## مواءمة الأهداف

ربط جهود الأمن السيبراني بأهداف العمل والاستراتيجية العامة

2

## إدارة المخاطر

توفير رؤية شاملة للمخاطر واتخاذ قرارات مبنية على أولويات واضحة

3

## الامتثال التنظيمي

الالتزام بالأنظمة والتشريعات المحلية والدولية ذات الصلة

4

## بناء الثقة

طمأنة العملاء والشركاء والمستثمرين حول جدية حماية بياناتهم

# الحوكمة مقابل الإدارة

## الحوكمة (Governance)

- وضع التوجهات والأهداف الاستراتيجية
- اعتماد السياسات والإشراف عليها
- تحديد المسؤوليات والمساءلة
- متابعة الأداء العام على مستوى المجلس

## الإدارة (Management)

- التنفيذ اليومي للأنشطة والمهام
- تطبيق السياسات والإجراءات المعتمدة
- الاستجابة التشغيلية للحوادث
- تقارير الأداء التشغيلي

# الأركان الأساسية لحوكمة أمن المعلومات

1

## القيادة والالتزام

دعم واضح من الإدارة العليا ومجلس الإدارة

2

## الهيكل التنظيمي

تحديد الأدوار والمسؤوليات بوضوح داخل المؤسسة

3

## السياسات والمعايير

وثائق ناظمة توجّه السلوك والقرارات الأمنية

4

## إدارة المخاطر

تحديد المخاطر وتقييمها ومعالجتها بشكل منهجي

5

## الامتثال

الالتزام بالمتطلبات القانونية والتنظيمية ذات الصلة

6

## قياس الأداء

مؤشرات ومراجعات دورية لتقييم فعالية الحوكمة

# من يشارك في حوكمة أمن المعلومات؟

1. **مجلس الإدارة**
   يضع التوجهات العليا ويراقب الالتزام بها على مستوى المؤسسة

2. **الإدارة التنفيذية**
   تترجم توجهات المجلس إلى استراتيجيات وخطط قابلة للتنفيذ

3. **مسؤول أمن المعلومات (CISO)**
   يقود البرنامج الأمني ويرفع التقارير للإدارة العليا

4. **الموظفون والمستخدمون**
   يلتزمون بالسياسات ويشكلون خط الدفاع الأول في الممارسة اليومية

# المشهد التشريعي والتنظيمي )لمحة عامة(

1. **أنظمة حماية البيانات الدولية**
   مثل اللائحة الأوروبية العامة لحماية البيانات GDPR

2. **الأنظمة والتشريعات المحلية**
   قوانين حماية البيانات وأمن المعلومات الخاصة بكل دولة

3. **متطلبات القطاعات الحساسة**
   قطاعات كالمال والصحة تخضع لمتطلبات تنظيمية إضافية

4. **أهمية الامتثال**
   يشكل الامتثال جزءاً أساسياً من حوكمة أمن المعلومات وليس مجرد التزام قانوني

نظرة تمهيدية

# أطر الحوكمة التي سندرسها لاحقاً

1

## NIST CSF 2.0

إطار أمريكي شامل يضم وظيفة مخصصة للحوكمة (Govern)

2

## ISO/IEC 27014

معيار دولي متخصص في حوكمة أمن المعلومات

3

## ISO/IEC 27001

معيار عالمي لأنظمة إدارة أمن المعلومات وشهادة الاعتماد

4

## COBIT 2019

إطار متكامل لحوكمة تقنية المعلومات على مستوى المؤسسة

# مفهوم المخاطر السيبرانية

1. **الخطر Risk**
   احتمال وقوع حدث يؤثر سلباً على أصول المؤسسة أو أهدافها

2. **التهديد Threat**
   أي مصدر محتمل يمكن أن يستغل ثغرة لإحداث ضرر

3. **الثغرة Vulnerability**
   نقطة ضعف في النظام يمكن استغلالها من قبل التهديد

4. **لماذا يهم في الحوكمة؟**
   إدارة المخاطر تُترجم القرارات الاستراتيجية إلى إجراءات عملية ـــسنتوسع فيها لاحقاً

# فرص العمل في حوكمة الأمن السيبراني

1

## مسؤول أمن المعلومات CISO

القيادة الاستراتيجية لبرنامج الأمن السيبراني

2

## محلل امتثال ومخاطر

تقييم الالتزام بالسياسات والمعايير التنظيمية

3

## مدقق أمن المعلومات

مراجعة الضوابط الأمنية والتحقق من فعاليتها

4

## مستشار حوكمة تقنية المعلومات

دعم المؤسسات في بناء أطر حوكمة فعالة

# أهم المصطلحات في هذه المحاضرة

| | |
|---|---|
| **Cybersecurity** | الأمن السيبراني :حماية الأنظمة والشبكات والبيانات من التهديدات الرقمية |
| **CIA Triad** | مثلث السرية والسلامة والتوافر، ركيزة أمن المعلومات الأساسية |
| **Governance** | الحوكمة :أنظمة توجيه ومراقبة أداء المؤسسة لتحقيق أهدافها |
| **CISO** | مسؤول أمن المعلومات الأول، المسؤول التنفيذي عن البرنامج الأمني |
| **Compliance** | الامتثال :الالتزام بالمتطلبات القانونية والتنظيمية والمعيارية |
| **Risk** | الخطر :احتمال تأثر أصول المؤسسة سلباً نتيجة تهديد يستغل ثغرة |

نشاط تفاعلي

# سؤال للنقاش

*برأيك، لماذا لا تكفي الحلول التقنية وحدها لحماية المؤسسات من التهديدات السيبرانية؟*

- فكّر في دور السياسات والوعي البشري
- فكّر في دور القيادة العليا في اتخاذ القرار
- شارك مثالاً واقعياً إن أمكن

# أهم ما ينبغي تذكّره من هذه المحاضرة

1. الأمن السيبراني يقوم على حماية السرية والسلامة والتوافر لأصول المعلومات
2. التهديدات متنوعة ومتطورة، وتشمل عوامل تقنية وبشرية معاً
3. حوكمة أمن المعلومات توجّه القرارات الأمنية وتربطها بأهداف المؤسسة
4. الحوكمة تختلف عن الإدارة :الأولى توجّه وتراقب، والثانية تنفّذ وتشغّل
5. الأركان الستة للحوكمة تشكل الأساس الذي سنبني عليه بقية المقرر

التحضير للقادم

# نظرة على الأسبوع الثاني

1. **الموضوع القادم**
   الفرق بين الحوكمة والإدارة في الأمن السيبراني

2. **سيتم التوسع في**
   أدوار كل من مجلس الإدارة، الإدارة التنفيذية، والفرق التشغيلية

3. **تحضير مطلوب**
   مراجعة مفاهيم هذه المحاضرة، خاصة أركان الحوكمة وأصحاب المصلحة

# المراجع والمصادر

مصادر مقترحة لتعميق الفهم حول مواضيع هذه المحاضرة

— NIST Cybersecurity Framework (CSF) 2.0 — National Institute of Standards and Technology

— ISO/IEC 27001 & ISO/IEC 27014 — المنظمة الدولية للمعايير

— COBIT 2019 Framework — ISACA

— شكراً لحسن استماعكم — الأسئلة مرحّب بها

# حوكمة الأمن السيبراني

**الاسبوع الثالث**

**إطار NIST CSF 2.0 للامن السيبراني ووظيفة الحوكمة (Govern)**

**أستاذ المادة**

**أ.د. ضياء جاسم كاظم**

# المحور الأول: نشأة NIST ونشأة الإطار CSF

فهم الجذور التاريخية والطبيعة التنظيمية للمعهد الوطني للمعايير والتقنية

NIST : National Institute of Standards and Technology
CSF: Cyber Security Framework

# المعهد الوطني للمعايير والتقنية (NIST)

**تعريف المعهد:** وكالة فيدرالية أمريكية غير تنظيمية تتبع وزارة التجارة، تُعنى بتطوير **لمعايير القياسية والتقنية لتعزيز الابتكار والأمن.**

- **معايير مرجعية طوعية:** لا تملك صفة القانون الملزم بذاتها، ولكنها تُعتمد كمرجع عالمي رئيسي.
- **لغة مشتركة للشركات:** تتيح للمؤسسات بمختلف أحجامها تقييم نضجها الأمني وربطه بأهداف العمل.
- **المرونة والتكيف:** صُمم الإطار ليتناسب مع قطاعات التكنولوجيا، المالية، والصحية وغيرها.

# التطور التاريخي لإطار NIST CSF

**2014 - CSF 1.0**

النسخة الأولى: ركّزت بشكل أساشي على حماية البنية التحتية الحيوية الطاقة، الاتصالات، الصحة.

**2018 - CSF 1.1**

التحديث الأولي: أضاف مفاهيم قياس المخاطر وإدارة مخاطر سلسلة التوريد والتقييم الذاتي.

**2024 - CSF 2.0**

النقلة النوعية: توسع النطاق ليشمل جميع القطاعات، مع استحداث وظيفة الحوكمة (Govern).

# المستجدات والتغيرات الجوهرية في CSF 2.0

### شمولية نطاق التطبيق

لم يعد الإطار حصرياً للبنى التحتية الحيوية، بل أصبح أدلة عالمية قابلة للتطبيق في الناشئة، المؤسسات الصغيرة، والشركات العالمية على حد سواء.

### إضافة وظيفة الحوكمة (Govern)

إفراد الحوكمة كوظيفة مستقلة ومركزية تُوجّه الوظائف الخمس الأخرى، لضمان ارتباط الأمن السيبراني بالاستراتيجية العليا للمؤسسة.

# المحور الثاني: الهيكلية الجديدة والوظائف الست

استعراض البنية المفاهيمية لإطار CSF 2.0 وكيف تتكامل الوظائف التشغيلية

# الوظائف الست الأساسية للإطار

### 1. الحوكمة (Govern)

تحديد الاستراتيجية، أولويات المخاطر، والسياسات، والمسؤوليات التوجيهية.

### 2. التعرّف (Identify)

حصر الأصول، الأجهزة، والبيانات، وفهم البيئة التشغيلية والمخاطر.

### 3. الحماية (Protect)

وضع الضوابط الوقائية لضمان استمرار تقديم الخدمات الحيوية.

### 4. الكشف (Detect)

تحديد وقوع الحوادث والأحداث السيبرانية الشاذة بشكل سريع ومباشر.

### 5. الاستجابة (Respond)

اتخاذ الإجراءات الفورية واحتواء الحادث السيبراني والحد من أثره.

### 6. التعافي (Recover)

استعادة القدرات والخدمات المتأثرة وتعزيز المرونة التنظيمية.




# الحوكمة في قلب الإطار السيبراني

## السياق الاستراتيجي الموجه

في النسخة السابق 1.1، كانت عناصر الحوكمة مبعثرة ضمن وظيفة التعرّف (ID.GV). أدركت NIST أن الأمن السيبراني ليس مجرد مهمة تقنية لحماية الأجهزة، بل هو مسؤولية قيادية عليا.

تضع الحوكمة "شهية المخاطر" وتحدد الموارد والمسؤوليات التي تبنى عليها باقي الوظائف الست : التعرف، الحماية، الكشف، الاستجابة، والتعافي.

# المحور الثالث: الفئات الست لوظيفة الحوكمة

تحليل دقيق وعميق للفئات التفصيلية (GV Categories) في CSF 2.0

# GV.OC : السياق التنظيمي (Organizational Context)

- **فهم رسالة المؤسسة وأهدافها:** لا يمكن وضع حماية سيبرانية فعالة دون فهم طبيعة عمل المؤسسة، أهدافها التجارية، أو خدماتها الحكومية.
- **الالتزامات القانونية والتنظيمية:** حصر القوانين، اللوائح، والاشتراطات التعاقدية التي تجب مراعاتها (مثل أنظمة هيئة الأمن السيبراني NCA).
- **توقعات أصحاب المصلحة:** تحديد متطلبات العملاء، الشركاء، والمستثمرين فيما يتعلق بالخصوصية والسرية.
- **ربط القرار السيبراني بالواقع التشغيلي:** ضمان أن القرارات الأمنية تساند استمرارية الأعمال ولا تعوق الابتكار.

# GV.RM : استراتيجية إدارة المخاطر

### شهية المخاطر (Risk Appetite)

تحديد حدود مستويات المخاطر السيبرانية التي تقبل الإدارة العليا تحملها في سبيل تحقيق أهدافها المؤسسية، وتحديد سقف التحمل (Risk Tolerance).

### خيارات الاستجابة والافتراضات

تحديد الأطر العامة لمعالجة المخاطر: القبول، الحد، نقل الخطر (كالـتأمين السيبراني)، أو تجنب الخطر، وتوفير الميزانيات اللازمة للتمويل.

# GV.RR : الأدوار والمسؤوليات والصلاحيات

| المستوى التنظيمي | المسؤولية الجوهرية | آلية المساءلة |
|---|---|---|
| **مجلس الإدارة / القيادة العليا** | اعتماد الاستراتيجية، إقرار شهية المخاطر، وتوفير الموارد. | تقارير دورية عن حالة النضج والمخاطر العابرة. |
| **الرئيس التنفيذي للأمن (CISO)** | تطوير وتطبيق برنامج الأمن السيبراني والإشراف التشغيلي. | مؤشرات الأداء الرئيسية (KPIs) ونسبة امتثال الضوابط. |
| **الفرق التشغيلية والموظفون** | التنفيذ اليومي للسياسات والالتزام بالتعليمات الأمنية. | اختبارات التوعية والتدقيق الداخلي المستمر. |

# GV.PO : سياسات الأمن السيبراني التنظيمية

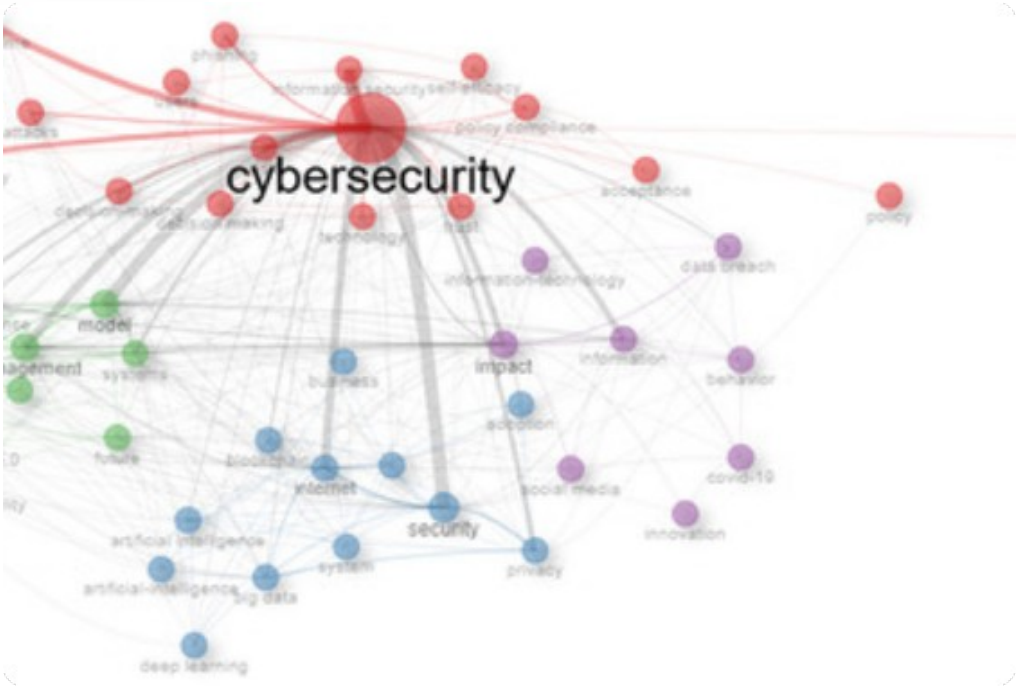
- **صياغة واعتماد السياسات:** إعداد سياسات مكتوبة وشاملة تعكس التوجهات الاستراتيجية والمتطلبات التنظيمية.
- **التواصل والتوعية الشاملة:** نشر السياسات وتعميمها على جميع الموظفين والمقاولين بأسلوب واضح ومفهوم.
- **الإنفاذ والإلزام:** وضع آليات تحقق لضمان تطبيق السياسات مع وجود جزاءات واضحة للمخالفات.
- **المراجعة والتحديث الدوري:** مراجعة السياسات سنوياً أو عند حدوث تغيرات تقنية وجوهرية في البيئة التشغيلية.

# GV.OV : الرقابة والإشراف المستمر




*استخدام نتائج التقييمات والتدقيق الدوري لتعديل وتحديث استراتيجية إدارة المخاطر وتوجيه القرار القيادي (Oversight) تتضمن وظيفة الرقابة.*

# GV.SC : إدارة مخاطر سلسلة التوريد




مع اعتماد المؤسسات على السحابة والموردين الخارجيين، أصبحت سلسلة التوريد من أكبر متجهات الهجوم (Attack Vectors).

- **تقييم الموردين:** إدراج المتطلبات الأمنية في العقود والاتفاقيات (SLAs).
- **المراقبة المستمرة:** التحقق الدوري من النضج الأمني للطرف الثالث.
- **خطة الطوارئ المشتركة:** ضمان التنسيق في حال تعرض المورد لخرق سيبراني.

# المحور الرابع: أدوات التطبيق والقياس

كيف تحول المؤسسات الإطار النظري إلى ممارسة عملية مقاسة؟

# مستويات تطبيق الإطار (Implementation Tiers)

4

مستويات لتحديد نضج إدارة المخاطر

1. **المستوى 1 (جزئي - Partial):** الممارسات عشوائية وردود أفعال غير مدونة.
2. **المستوى 2 (مستنير بالمخاطر - Risk Informed):** وجود سياسات لكن تطبيقها غير منتظم.
3. **المستوى 3 (قابل للتكرار - Repeatable):** ممارسات موثقة ومؤسسية ومطبقة بانتظام.
4. **المستوى 4 (متكيف - Adaptive):** الاستجابة الديناميكية والتعلم المستمر من التهديدات.

# الملفات التعريفية (**Profiles**) وتحليل الفجوة

### الملف الحالي (Current Profile)

توصيف دقيق ومباشر لحالة الضوابط والممارسات الأمنية المطبقة فعلياً في الوقت الراهن داخل المؤسسة.

### الملف المستهدف (Target Profile)

تحديد الأهداف والأوضاع الأمنية المطلوب الوصول إليها بناءً على شهية المخاطر ومتطلبات العمل.

### تحليل الفجوة وخطة العمل

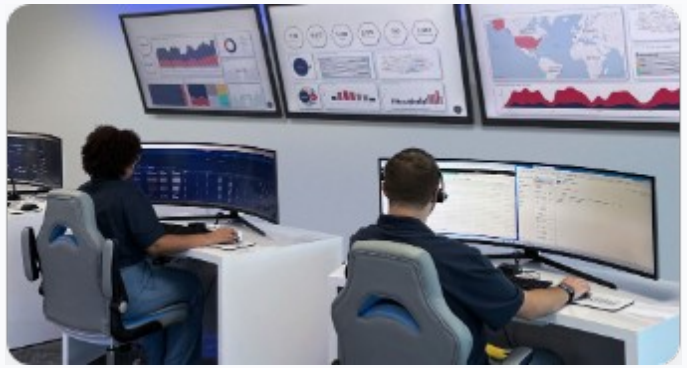
مقارنة الملفين لتحديد الفجوات (Gaps) وصياغة خطة خارطة طريق (Roadmap) ذات أولويات ميزانية تنفيذية.

# سيناريو تطبيقي: الحوكمة في الممارسة العلمية




## 1. التوجيه القيادي

يقوم المجلس بوضع شهية المخاطر واعتماد الاستراتيجية والسياسات العامة للأمن السيبراني.



## 2. التنفيذ التشغيلي

يقوم فريق CISO بتطبيق ضوابط Protect & Detect استناداً للسياسات المعتمدة.



## 3. الرقابة والتقييم

رفع تقارير الأداء ومراجعة مخاطر الموردين لتعديل الاستراتيجية وتحديثها بشكل دوري.

# المحور الخامس: الخلاصة والآفاق المستقبلية

أبرز التوصيات الأكاديمية والمفاهيم المحورية للمحاضرة

برنامج الدبلوم العالي في حوكمة الأمن السيبراني

# المحاضرة الرابعة : معيار ISO 27014 و ISO 27001

إعداد: أ.د. ضياء جاسم كاظم

المدخل المفاهيمي

# العلاقة بين الحوكمة والإدارة

فهم الفارق الجوهري والتكامل الوظيفي بين التوجيه الاستراتيجي والتطبيق الفني والعملياتي.

# معيار ISO/IEC 27001: نظام إدارة أمن المعلومات




## ما هو معيار ISO/IEC 27001؟

يعد المعيار الدولي الأبرز المخصص لتأسيس، تطبيق، تشغيل، ومراجعة نظام إدارة أمن المعلومات ISMS-Information Security Managmeent System

- ويركز المعيار على إدارة المخاطر السيبرانية وحماية أصول المعلومات.
- يعتمد على دورة التخطيط والتنفيذ والمفاهيم الإدارية المستمرة Plan-Do-Check-Act -(PDCA).
- يحدد المتطلبات الإدارية والتقنية القابلة للتدقيق والمنح الشهادي.
- يضمن استمرارية الأعمال وحماية سرية وسلامة وتوافر البيانات.

# معيار ISO/IEC 27014 حوكمة الأمني




## إطار حوكمة أمن المعلومات للمؤسسات

يركز معيار **ISO/IEC 27014** على الدور الاستراتيجي لمجلس الإدارة والإدارة العليا في قيادة الأمن السيبراني.

يقدم إرشادات شاملة لكيفية تقييم، توجيه، ومراقبة أنشطة أمن المعلومات لضمان توافقها التام مع الأهداف الاستراتيجية للمؤسسة وتحقيق القيمة المضافة.

# التكامل والفرق الأساسي بين المعيارين

## معيار ISO/IEC 27014 (الحوكمة)

المستوى: مجلس الإدارة والإدارة التنفيذية العليا.

التركيز: الرؤية الاستراتيجية، المبادئ، المساءلة، وتوجيه الاستثمارات الأمنية.

السؤال الجوهري: هل نقتني ونتوجه نحو الاتجاه الصحيح الذي يحمي المؤسسة ويكفل نموها؟

## معيار ISO/IEC 27001 (الإدارة)

المستوى: إدارة تكنولوجيا المعلومات والأمن السيبراني التشغيلية.

التركيز: تصميم الضوابط الأمنية، إدارة المخاطر اليومية، وتطبيق السياسات.

السؤال الجوهري: هل نطبق العمليات الأمنية والضوابط بشكل صحيح وفعال؟

# المبادئ الاساسية لحوكمة الأمن (ISO 27014)

## المحاذاة الاستراتيجية

ربط استراتيجية الأمن السيبراني بأهداف العمل المؤسسي المباشرة.

## توليد القيمة

تحقيق عائد استثماري أمني يعزز كفاءة المؤسسة وثقة العملاء.

## المساءلة والامتثال

تحديد المسؤوليات والالتزام بالقوانين والتشريعات الوطنية والدولية.

# مؤشرات أداء الحوكمة والامتثال

**100%**

التزام الإدارة العليا بالمساءلة

## تأثير الحوكمة على تقليل المخاطر السيبرانية

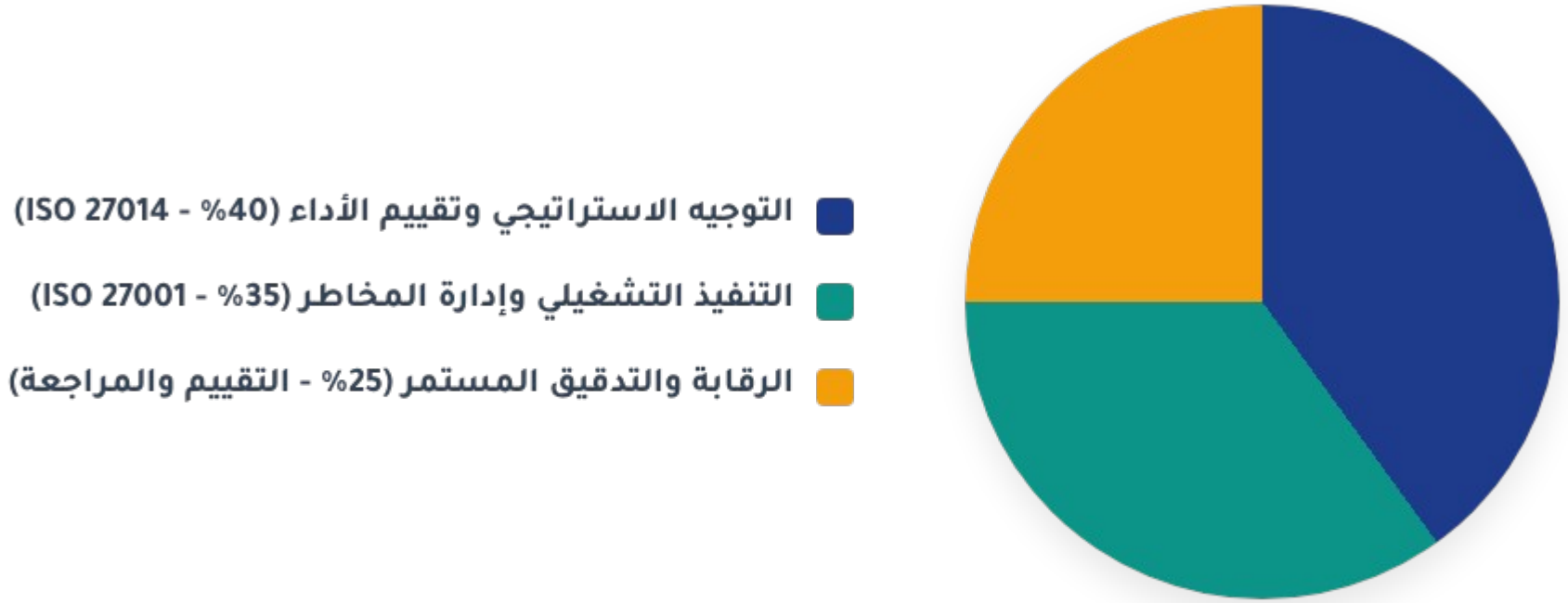
تثبت الدراسات والأبحاث الأكاديمية أن المؤسسات التي تدمج معيار **ISO 27014** مع **ISO 27001** تحقق انخفاضاً جوهرياً في الثغرات الحرجية ونسبة نجاح الحوادث السيبرانية.

تضمن الحوكمة الرشيدة توفير التمويل والموارد الكافية لفرق الأمن التشغيلية للقيام بمهامها بفاعلية.

# مقارنة تفصيلية بين ISO 27001 و ISO 27014

| وجه المقارنة | معيار ISO/IEC 27001 | معيار ISO/IEC 27014 |
|---|---|---|
| طبيعة المعيار | معيار متطلبات قابل للتدقيق والمنح الشهادي (Certification). | معيار إرشادي للحوكمة (Guidance Standard). |
| الجمهور المستهدف | مدراء الأمن السيبراني (CISO) والفرق الفنية والإدارية. | مجلس الإدارة (Board of Directors) والإدارة العليا. |
| العمليات الأساسية | تقييم المخاطر، معالجة المخاطر، والتحسين المستمر. | التقييم (Evaluate)، التوجيه (Direct)، والمراقبة (Monitor). |
| الهدف الرئيسي | بناء وتنفيذ ضوابط أمنية تشغيلية لحماية البيانات. | كفالة التوجيه الاستراتيجي والمساءلة المؤسسية. |

# توزيع أدوار الحوكمة والإدارة




*يوضح الشكل مدى تكامل أنشطة الحوكمة والإدارة والتدقيق لبناء منظومة أمنية متماسكة ومستدامة.*

# مراحل تطبيق إطار الحوكمة والـ ISMS

### 1. التقييم والتوجيه

تحديد التوجه الاستراتيجي وسياق المؤسسة وفق ISO 27014.

### 2. التخطيط والتصميم

بناء سياسات ISO 27001 وتقييم المخاطر الأولوية.

### 3. التطبيق والتشغيل

تنفيذ الضوابط الأمنية وتدريب الكوادر البشرية.

### 4. المراقبة والتحسين

إجراء التدقيق الداخلي ورفع التقارير لمجلس الإدارة.

# الخلاصة الاستراتيجية للطلبة

إن النجاح في حوكمة الأمن السيبراني يتطلب خلق جسر متين بين القرارات الصادرة من غرفة مجلس الإدارة (ISO 27014) والتطبيقات الميدانية التي ينفذها مهندسو ومدراء الأمن السيبراني (ISO 27001). بدون هذا التكامل، تبقى الحوكمة مجرد شعارات، ويبقى الأمن التشغيلي معزولاً عن اهتمامات المؤسسة.

# باب الأسئلة والمناقشة

طلبتنا الأعزاء: كيف يمكن لمجلس الإدارة قياس كفاءة تطبيق ISO 27001 عملياً؟

محاضرة أكاديمية - الدبلوم العالي

# إطار COBIT 2019 وحوكمة تكنولوجيا المعلومات

COBIT (Control Objectives for Information and Related Technology) by
ISACA (Information Systems Audit and Control Association)

إعداد:
أ.د. ضياء جاسم كاظم

# محاور الدراسة الرئيسية



### مفاهيم الحوكمة

التمييز بين الحوكمة والإدارة وتحديد الأدوار والمسؤوليات.



### هيكلية COBIT 2019

المبادئ التسعة والمكونات السبعة والنموذج المرجعي لـ 40 هدفاً.



### تكامل الأمن السيبراني

ربط الأهداف الأمنية بإطار COBIT والمعايير الدولية ISO و NIST

# ما هي حوكمة تكنولوجيا المعلومات؟

مجموعة المبادئ والتنظيمات التي تضمن دعم تقنية المعلومات لأهداف المؤسسة الاستراتيجية وتحقيق القيمة المضافة.

### الغاية الجوهرية للحوكمة

تحقيق التوازن الأمثل بين خلق القيمة وتحسين المستويات الأمنية وتقليل المخاطر.

### الأركان الثلاثة للحوكمة

- تحقيق الفوائد: تعظيم العائد من الاستثمار الرقمي.
- تحسين المخاطر: حماية الأصول والمعلومات الحساسة.
- أمثلية الموارد: الاستخدام الكفء للبنية التحتية.

# التمييز الجوهري: الحوكمة مقابل الإدارة

مسؤولية مجلس الإدارة

## الحوكمة (Governance)

تختص بالتوجيه والتقييم والمراقبة لضمان تحقيق الأهداف العليا.

**الأنشطة: التقييم (Evaluate) - التوجيه (Direct) - المراقبة (Monitor)**

مسؤولية الإدارة التنفيذية

## الإدارة (Management)

تختص بالتخطيط والبناء التشغيلي والتنفيذ اليومي للأنشطة.

**الأنشطة: التخطيط (Plan) - البناء (Build) - التشغيل (Run)**

# تعريف إطار COBIT 2019

## إطار عمل عالمي طورته منظمة ISACA  يوفر منهجية شاملة لحوكمة وإدارة المعلومات والتكنولوجيا في المؤسسات.

تطور الإطار: صدر عام 2019  ليتناسب مع التقنيات الحديثة والتحول الرقمي.

الميز الأساسية: المرونة العالية والملاءمة مع متطلبات كل مؤسسة.



### معيار قطاعي عالمي

جسر يربط الفجوة بين الإدارة العليا وفرق الأمن السيبراني وتقنية المعلومات.

ISACAاختصارًا لـ Information Systems Audit and Control Association هي جمعية مهنية عالمية غير ربحية تُعنى بحوكمة تكنولوجيا المعلومات، التدقيق، إدارة المخاطر، والأمن السيبراني. تأسست عام 1969 وتعد المرجع الأول دولياً لتطوير ممارسات وأطر العمل في هذه المجالات.

# المبادئ الستة لنظام الحوكمة

### 1. تلبية احتياجات الأطراف

توليد القيمة وأهداف الأعمال.

### 2. النهج الشامل

تغطية المؤسسة كمنظومة متكاملة.

### 3. نظام ديناميكي

التكيف المستمر مع المتغيرات.

### 4. فصل الحوكمة عن الإدارة

تمكيز واضح للأدوار والمسؤوليات.

### 5. التخصيص حسب الاحتياج

تعديل النظام وفق سياق المؤسسة.

### 6. حوكمة شاملة للطرفين

تغطية التقنية والبيانات والمخاطر.

# مبادئ إطار الحوكمة الثلاثة

### 1. مبني على المكونات

يعتمد على عناصر تفاعلية توفر النظام الحاكم بكل فاعلية.

### 2. مفتوح وحيوي

يتيح إضافة محتويات وأساليب جديدة دون الإخلال بالمرجعية.

### متوافق مع المعايير

يتنسق مع الأطر والأنظمة المعترف بها كـ ISO & NIST

# المكّونات السبعة لنظام الحوكمة (Governance Components)

العمليات (Processes)

الهياكل التنظيمية

المبادئ والسياسات

المعلومات والبيانات

الثقافة والسلوكيات

الخدمات والتطبيقات

الأفراد والمهارات

# مجالات COBIT 2019 الخمسة (40 أهداف حوكمة وإدارة )

| | |
|---|---|
| **مجال الحوكمة : EDM**<br>(Evaluate, Direct, Monitor) | 5 أهداف |
| التوافق والتخطيط والتنظيم | 14 هدفاً |
| البناء والتملك والتطبيق | 11 هدفاً |
| التقديم والخدمة الدعم (العمليات والأمن) | 6 أهداف |
| الرصد والتقييم والقياس | 4 أهداف |

# أهداف الحوكمة المباشرة للأمن السيبراني

APO13 إطار

## إدارة الأمن الرقمي (Managed Security)

صياغة وتحديث نظام إدارة أمن المعلومات (ISMS) وتحديد مستويات الحماية ومتابعة تنفيذ السياسات.

DSS05 إطار

## إدارة خدمات الأمن التشغيلية

حماية الأنظمة التشغيلية من الاختراقات وإدارة الصلاحيات والتعامل المباشر مع الحوادث والتهديدات.

# عوامل التصميم (Design Factors)

تسمح عوامل التصميم بتكييف إطار COBIT 2019 ليناسب البيئة الأمنية والمخاطر الخاصة بكل مؤسسة.

**النتيجة التنفيذية**

بناء نظام حوكمة أمني مخصص خالٍ من التعقيد الزائد.

- ملف التهديدات السيبرانية (Threat Landscape)
- المتطلبات التنظيمية والامتثال القانوني
- دور وتطور تقنية المعلومات بالمؤسسة
- استراتيجية واستجابة المؤسسة للمخاطر

# مستويات القدرة والنضج (Capability Levels 0-5)

| 0 | 1 | 2 | 3 | 4 | 5 |
|---|---|---|---|---|---|
| **غير مكتمل** | **مُنفّذ** | **مُدار** | **مُحدد** | **قابل للقياس** | **مُحسّن** |
| غياب الأنشطة والضوابط | تحقيق الهدف بشكل أولي | تخطيط وقياس ومراجعة | توثيق ومعايير موحدة | قياس كمي ومؤشرات أداء | تطوير مستمر وابتكار |

# التكامل بين COBIT 2019 والأطر العالمية الأخرى

### ISO/IEC 27001

يوفر الضوابط التفصيلية لأمن المعلومات التي تحقق أهداف COBIT.

### NIST CSF

يركز على إدارة المخاطر الاستجابة المباشرة للحوادث والتعافي.

### ITIL 4

يدعم إدارة الخدمات التشغيلية التي تعتمد عليها الحوكمة.

# خطوات حوكمة حادث سيبراني باستخدام COBIT 2019

1. **التوجيه والتقييم (EDM03)**
   تحديد مستوى المخاطر المقبول وتوجيه سياسة الاستجابة للحوادث.

2. **التخطيط والتنظيم (APO12)**
   تقييم أثر الحادث على الأصول والمعلومات وتحديد خطة الطوارئ.

3. **التشغيل والاحتواء (DSS05)**
   تنفيذ إجراءات الاحتواء والأمن التقني ومعالجة الثغرة بشكل مباشر.

# إدارة المخاطر السيبرانية

## المفاهيم الأساسية والأطر النظرية للتقييم والمعالجة

المحاضرة من أعداد:

ا.د. ضياء جاسم كاظم

# صياغة الخطر السيبراني (Risk Formula)

المكونات الأساسية لتحديد مستوى التهديد على الأصول الرقمية

**الخطر = التهديد × الثغرة × التأثير**

الخطر السيبراني لا ينشأ إلا عند اقتران وجود **تهديد نشط** بوجود **ثغرة أمنية** تؤدي إلى **تأثير مباشر** على أهداف المؤسسة.

# العناصر الثلاثية للمخاطر السيبرانية

التعريفات الأساسية المعتمدة في معايير الحوكمة

### الأصول (Assets)

البيانات والأنظمة والبنية التحتية ذات القيمة الحيويّة للمؤسسة.

### الثغرات (Vulnerabilities)

نقاط الضعف البرمجية أو التنظيمية التي يمكن استغلالها.

### التهديدات (Threats)

الأحداث الحتمية أو المحتملة التي قد تسبب ضرراً للأصول.

# دورة حياة إدارة المخاطر السيبرانية

المراحل المتتابعة وفق معايير ISO 31000 وNIST

01
**تحديد المخاطر**
حصر الأصول والتهديدات والثغرات الحالية.

02
**تحليل وتقييم**
قياس الاحتمالية وتحديد شدة الأثر المتوقع.

03
**معالجة المخاطر**
تطبيق الضوابط والتخفيف وفق الأولويات.

04
**المراقبة والمراجعة**
متابعة مستمرة لتقييم كفاءة الضوابط.

# التحليل النوعي مقابل التحليل الكمي للمخاطر

مقارنة بين منهجيات قياس الخطر في بيئة الأعمال

### التحليل النوعي (Qualitative)

**الأسلوب :**مقاييس وصفية (مرتفع، متوسط، منخفض).

**المميزات :**سريع التنفيذ وقليل التكلفة.

**الاستخدام :**التقييم المبدئي وتحديد الأولويات العامة.

### التحليل الكمي (Quantitative)

**الأسلوب :**قيم مالية ورقمية محددة .(SLE, ALE)

**المميزات :**دقة عالية ودعم قرارات الاستثمار.

**الاستخدام :**قرارات ميزانيات الأمان الحساسة.

# خيارات معالجة المخاطر السيبرانية

الإستراتيجيات الأربع المعتمدة في الحوكمة التنظيمية

### التخفيف (Mitigation)

تطبيق ضوابط أمنية لتقليل الاحتمالية أو الأثر.

### النقل (Transfer)

تحويل الخطر لطرف ثالث كالتأمين السيبراني.

### الاجتناب (Avoidance)

إيقاف النشاط أو التقنية المسببة للخطر نهائياً.

### القبول (Acceptance)

قبول الخطر المتبقي ضمن مستويات التحمل.

# مصفوفة تقييم المخاطر (Risk Rating Matrix)

ربط احتمالية الحدوث بتأثير الخطر لتحديد الأولويات

| التأثير /الاحتمالية | تأثير منخفض | تأثير متوسط | تأثير مرتفع |
|---|---|---|---|
| احتمالية مرتفعة | متوسط | مرتفع | حرج جداً |
| احتمالية متوسطة | منخفض | متوسط | مرتفع |
| احتمالية منخفضة | منخفض | منخفض | متوسط |

# شهية المخاطر مقابل تحمّل المخاطر

تحديد الحدود التنظيمية لاتخاذ القرارات السيبرانية



**شهية المخاطر (Risk Appetite)**

مستوى الخطر الكلي الذي تستعد المؤسسة لقبوله لتحقيق أهدافها الاستراتيجية.

**تحمّل المخاطر (Risk Tolerance)**

مقدار الانحراف المقبول عن شهية المخاطر المحددة في الحالات التشغيلية.

# أبرز أطر إدارة المخاطر العالمية

المعايير المرجعية لمؤسسات الأعمال والقطاعات الحكومية




**NIST SP 800-30**

إطار متخصص لإجراء تقييمات المخاطر الشاملة لنظم المعلومات المتقدمة.

**ISO/IEC 27005**

المعيار الدولي لإدارة مخاطر أمن المعلومات المكمل لمنظومة ISO 27001.